PMC Managers

Governance & Integrity Controls

Response to the Portal Due-Diligence Questionnaire

Prepared: 28 October 2026 · Platform: www.pmcmanagers.com

This document responds point-by-point to the integrity and governance questions raised. Each answer states how the control actually works in the platform and, where relevant, shows evidence captured directly from the live system. We have deliberately distinguished controls that are fully enforced in software from those that are policy matters or still in build, so the picture is complete and accurate.

Status key

- ENFORCED — built into the software and demonstrated below
- IN PROGRESS — framework in place; live third-party integration being completed
- POLICY — a contractual / organisational matter rather than a software control

Summary

Control	Status
Two-cover sealing (technical vs financial)	**ENFORCED**
System gate: financial opens only after technical clearance	**ENFORCED**
Tamper-evident audit ledger + public verification	**ENFORCED**
AI tools blocked from financial data	**ENFORCED**
Manual-exceptions register	**ENFORCED**
Buyer public/private classification (two-person verify)	**ENFORCED**
Integrity committee + collusion indicators + recorded override	**ENFORCED**
Fee-waiver maker-checker control	**ENFORCED**
Per-country legal register (board-visible)	**ENFORCED**
Incident register + published service standard (SLA)	**ENFORCED**
Escrow signer independence + dual signature	**ENFORCED**
Supplier rating / reputation	**ENFORCED**
KYC / AML / sanctions screening (Refinitiv World-Check One)	**IN PROGRESS**

Introducer-commission conflict checks	**IN PROGRESS**
Platform liability / remedy	**POLICY**

1. Two-cover separation — technical vs financial

Q: Is the price-blinding real and database/server-enforced, or only hidden on screen? Is there a hard system gate that prevents the financial envelope from being opened before technical evaluation is complete? Who can override the separation, and is every override recorded?

Response

- Price, commercial notes and all commercial documents are stripped server-side from the API response for technical evaluators, and for everyone, until the financial envelope is formally opened. The figures never reach the browser, so they cannot be recovered client-side.
- Opening the financial envelope is blocked by the server (HTTP 412 “financial locked”) until technical clearance has been recorded. The gate applies to administrators too — there is no “skip technical” path.
- Every technical clearance and every financial open writes an actor-stamped entry to the tamper-evident audit ledger, so any override is permanently recorded.
- The AI bid-comparison tool has been changed so it no longer receives the price at all (verified by the automated test test_ai_compare_scope_has_no_price).

Status: ENFORCED

Note: the sealing is role-based server redaction that we have functionally tested. We recommend an independent penetration test before any formal certification statement.

2. Audit ledger

Q: Is the ledger truly immutable? Can an administrator edit it? Can an outside party verify it?

Response

- Every significant action is written to an append-only ledger where each entry is hashed together with the previous entry (SHA-256 hash chain).
- It is tamper-EVIDENT: if any stored row were altered, the chain no longer validates and the exact broken entry is pinpointed. We state this honestly rather than claim data “cannot be changed”.
- Any bidder or auditor can independently verify a single record via the public endpoint /api/v1/audit/verify-record (no login required), surfaced on the public Trust & Security page.

Status: ENFORCED (tamper-evident)

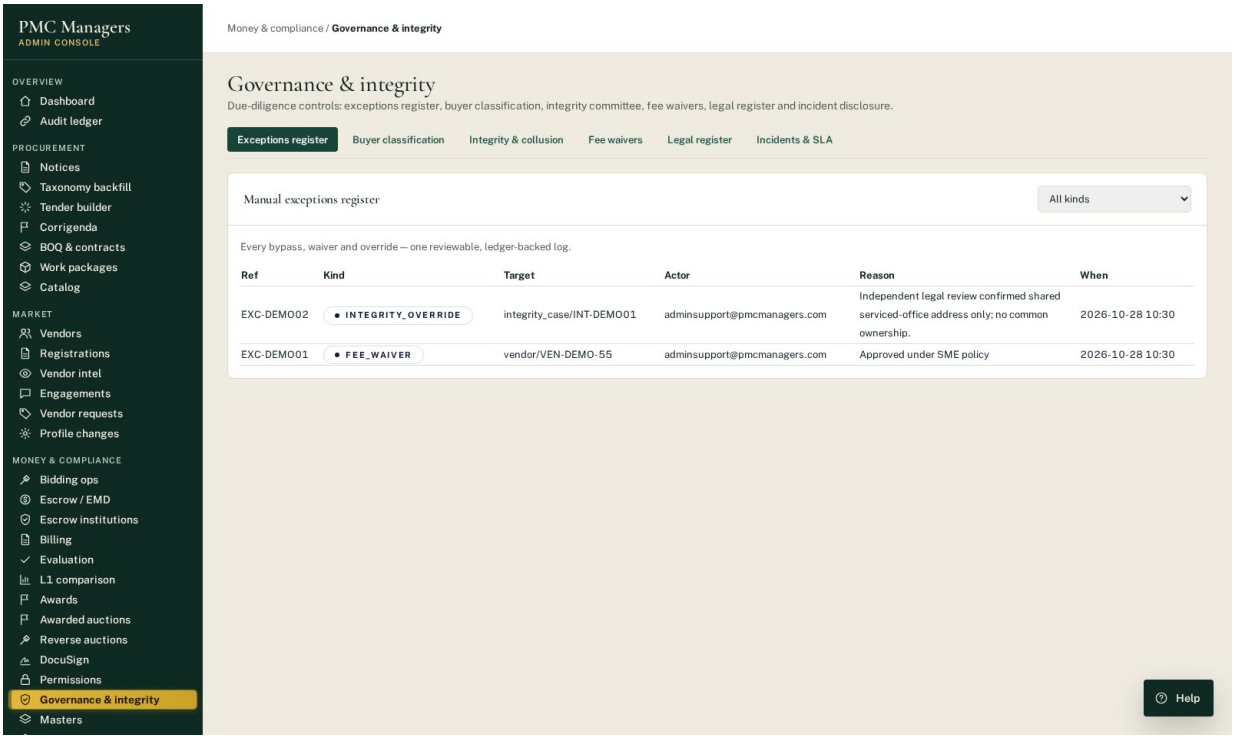
3. Manual-exceptions register

Q: Where is the record of manual exceptions — KYC bypasses, skipped stages, overrides — kept, and is it reviewable?

Response

- Every bypass, waiver and override is written to a single reviewable register and mirrored to the audit ledger, with the exception type, the target, the officer responsible, the reason and the timestamp.

Status: ENFORCED



Evidence: Manual-exceptions register in the admin console (demo data).

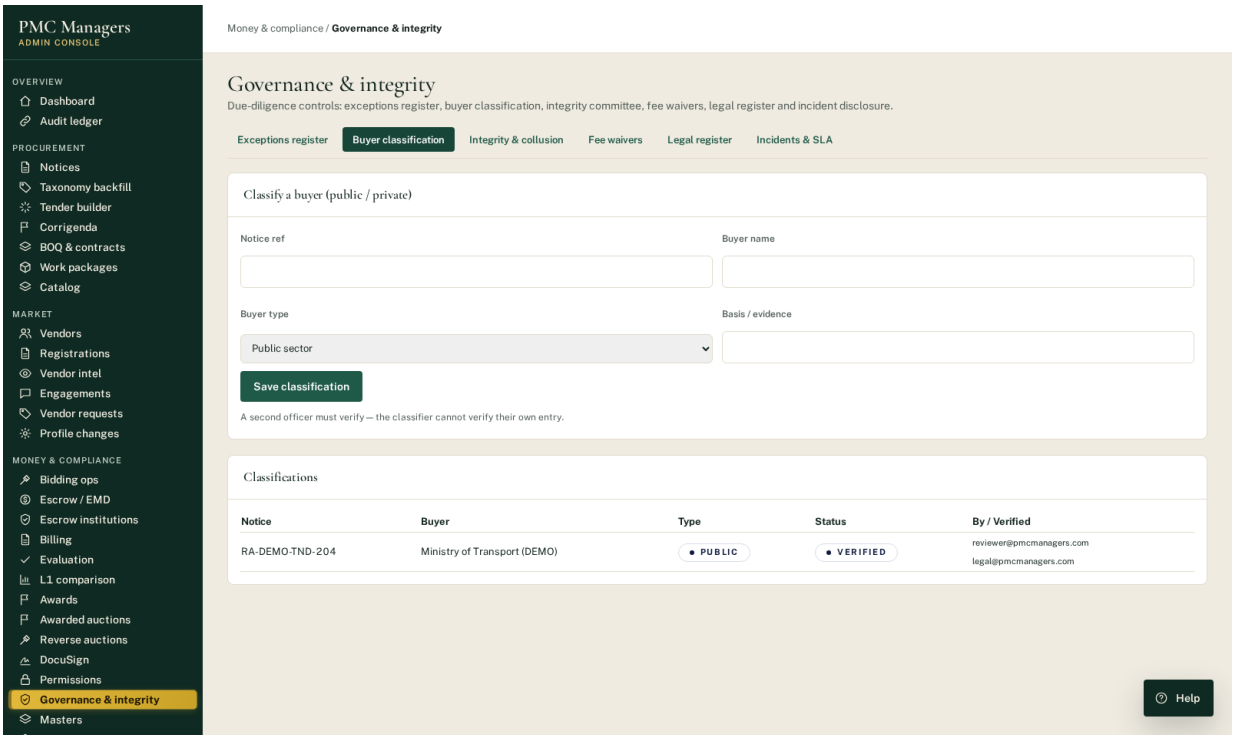
4. Buyer public / private classification

Q: How do you confirm whether a buyer is public or private, and who checks that this has been classified correctly?

Response

- One officer classifies the buyer (public / private) with the basis; a SECOND, different officer must verify it. The person who classified cannot verify their own entry (segregation of duties, enforced server-side — returns HTTP 403).
- A verified classification is locked and cannot be silently reset; the full history is retained.

Status: ENFORCED



Evidence: Buyer classification — note the different Classified-by vs Verified-by officers (demo data).

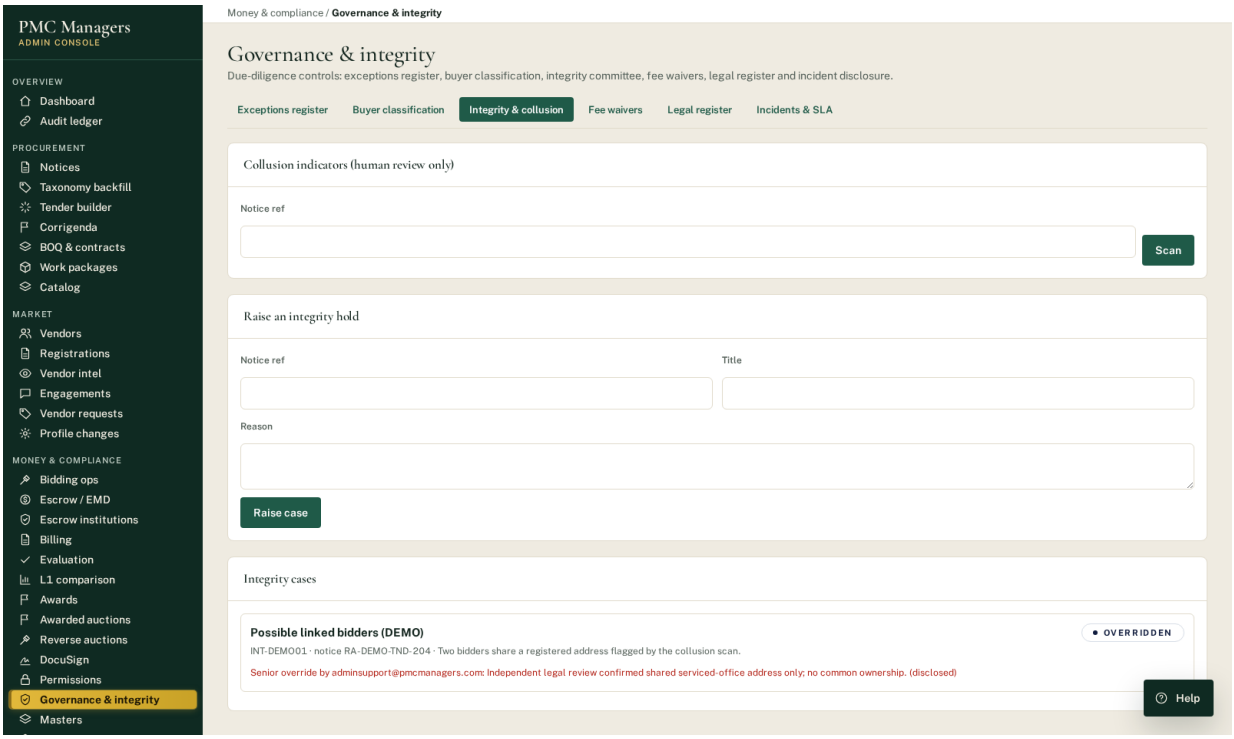
5. Integrity committee & collusion indicators

Q: How are hidden links between bidders (possible collusion) detected? Can a senior person override the integrity committee, and is that recorded?

Response

- Any officer can raise an integrity hold on a notice; the committee reviews and votes; cases follow a strict state machine so a resolved or overridden case cannot be silently changed.
- A senior officer may overrule the committee, but ONLY on the record: the override, its author and its reason are written to the ledger, logged in the exceptions register, and flagged as publicly disclosable.
- A collusion-indicator scan highlights bidders on the same notice that share an email domain, phone, registered address or bank account, and bidders that repeatedly bid together. These are prompts for human review, explicitly NOT proof of wrongdoing.

Status: ENFORCED



Evidence: Integrity case showing a recorded, disclosed senior override (demo data).

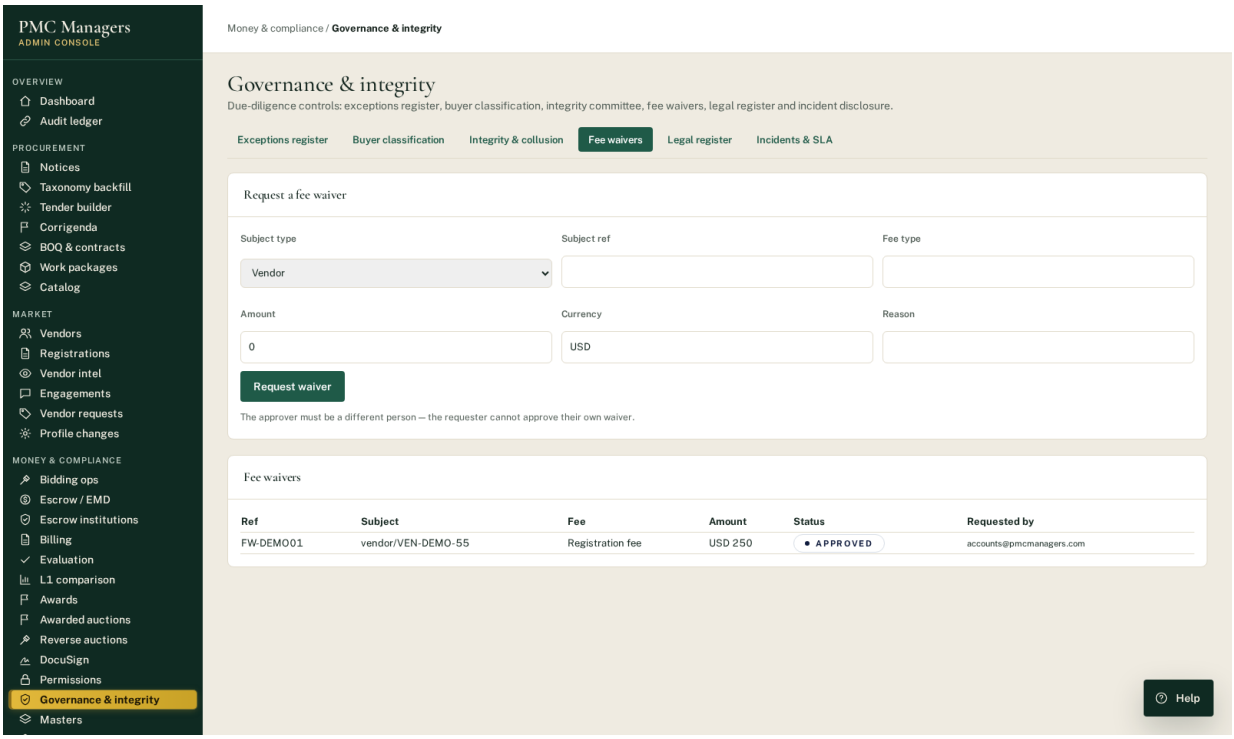
6. Fee waivers

Q: How do you prevent fee waivers being used to favour particular parties?

Response

- Fee waivers follow a maker-checker control: the officer who requests a waiver cannot approve it — a different officer must decide (enforced server-side, HTTP 403).
- Every approved waiver is automatically recorded in the exceptions register with the reason and both officers named.

Status: ENFORCED



Evidence: Fee-waiver workflow with maker-checker rule (demo data).

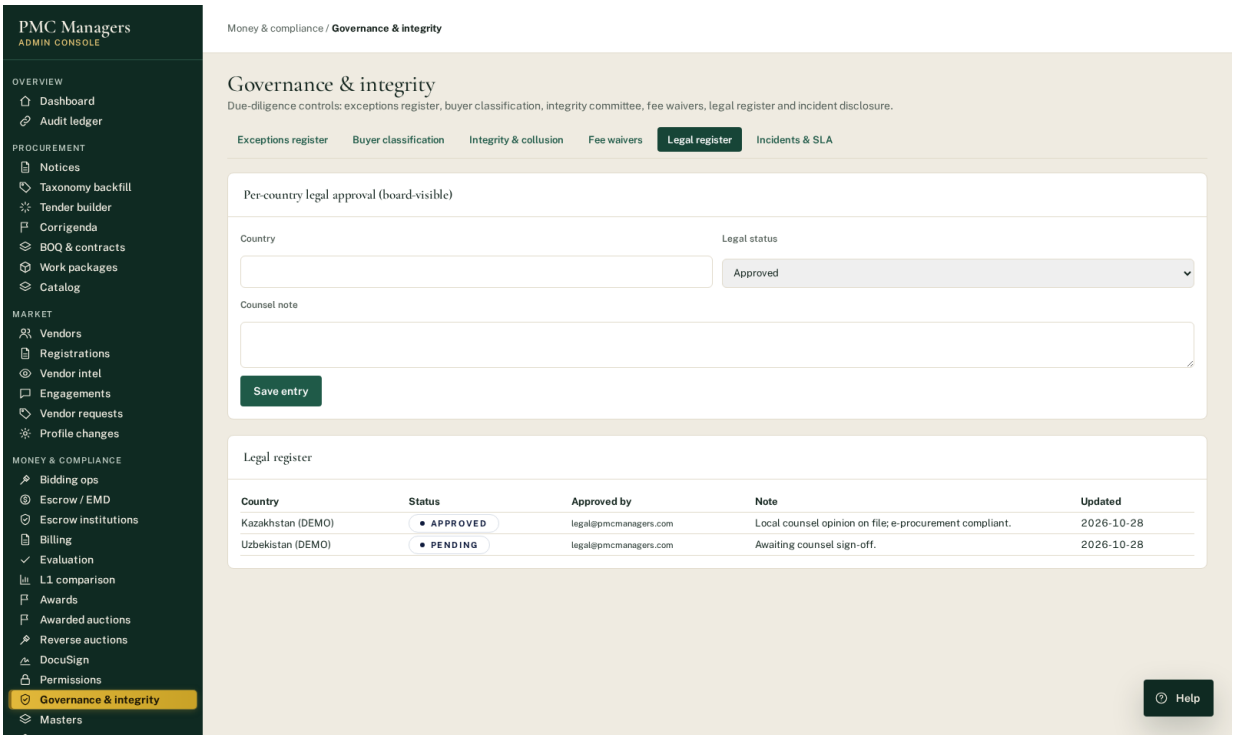
7. Per-country legal register

Q: Is legal approval for operating in each country recorded and visible to the Board?

Response

- A board-visible register records the legal status (approved / pending / blocked) for each country, the approving counsel and the note, with a full update trail.

Status: ENFORCED



Evidence: Per-country legal register (demo data).

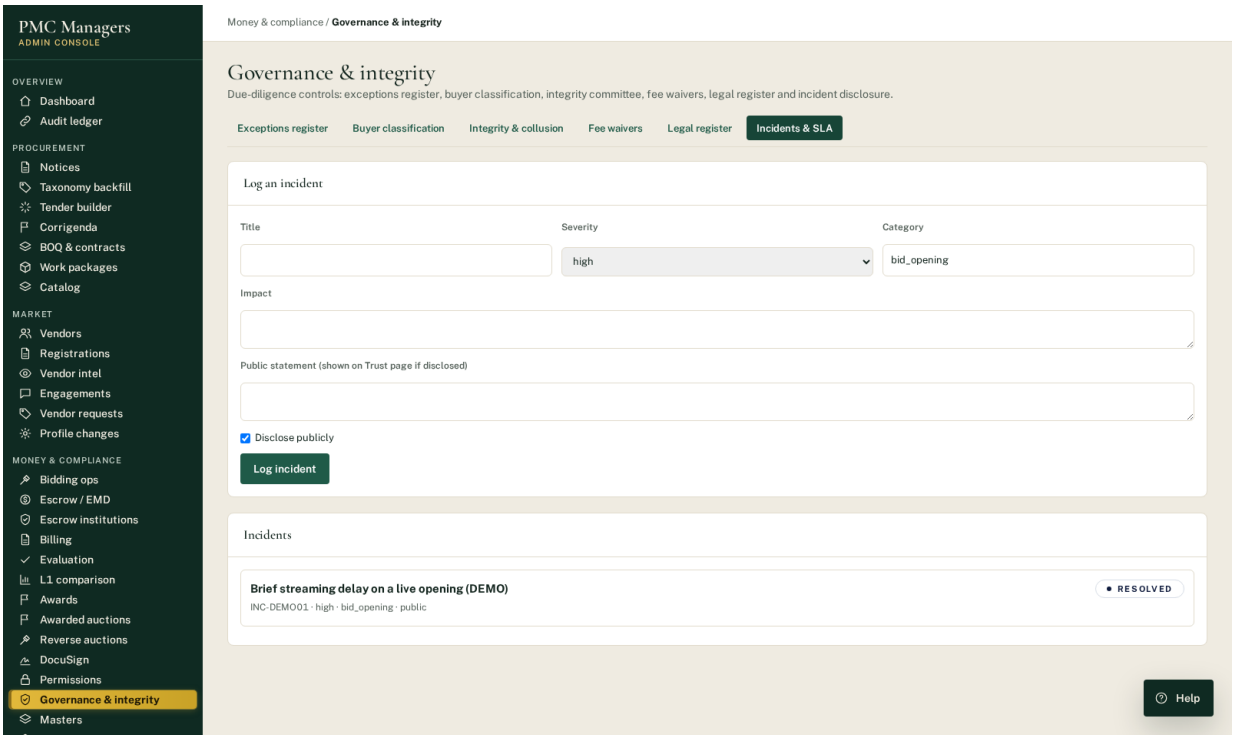
8. Incident disclosure & published service standard

Q: What happens if a live public bid-opening fails, and what is your service standard?

Response

- Live bid-opening rooms stream over SSE with an automatic polling fallback; if streaming fails the opening continues on a manual, audit-logged close, so no bid is lost.
- Incidents affecting a bid deadline or opening are logged and, where bidders are affected, publicly disclosed. A published service standard (SLA) is served to the public with no login required.

Status: ENFORCED



Evidence: Incident register with public disclosure (demo data).

Published service standard (live, public endpoint /api/v1/governance-controls/public/incidents):

- Bid Acceptance: Bids are accepted until the published deadline to the second, server-timestamped.
- Live Opening Uptime Target: 99.5% monthly availability for live bid-opening rooms.
- Live Opening Failover: Live rooms stream over SSE with automatic polling fallback; if streaming fails the opening continues on a manual, audit-logged close.
- Incident Disclosure: Any failure affecting a bid deadline or opening is logged and, where bidders are affected, publicly disclosed on this page.
- Support Response Critical: Critical incidents (deadline/opening affected) are acknowledged within 1 hour.

9. KYC / AML / sanctions screening

Q: Do you perform sanctions, beneficial-ownership and debarment checks, and are they kept up to date?

Response (full transparency)

- The KYC framework is in place — case records, manual-decision controls (with every manual override recorded in the exceptions register), and risk levels.
- Live screening is being connected to Refinitiv World-Check One (LSEG), to which the client holds a subscription. Until that integration is completed and switched on, the platform is NOT performing live sanctions / PEP / beneficial-ownership / debarment screening. We are stating this plainly rather than representing it as already live.

Status: IN PROGRESS — Refinitiv World-Check One integration being completed

10. Escrow independence, dual signature & secure links

Q: Is the escrow sign-off independent? Does the two-signature rule cover commission/franchise payments or only buyer escrow? Are the e-mail "magic links" protected?

Response

- Escrow signer independence is enforced: the PMC officer and the escrow-institution officer cannot be the same person (rejected at account level and by the e-signature envelope, which uses two independent signers).
- Escrow releases, refunds and fee-outs require BOTH signatures before funds move.
- Password-reset links are single-use and expire after one hour; sessions are time-limited.

Status: ENFORCED (escrow)

In build: a dedicated commission / franchise payout module (so the dual-signature rule extends there too) and tightening of the institution onboarding link to single-use. Disclosed for completeness.

11. Supplier rating & reputation

Response

- The platform operates a supplier rating system (peer, PMC and buyer reviews) with an approved-only public aggregate, anti-self-rating protection and reputation tiers.

Status: ENFORCED

12. Remaining items

Introducer-commission conflict checks

- No introducer-commission module exists yet; it will be added alongside the commission payout module. (IN PROGRESS)

Platform liability / remedy for harm

- This is a contractual and organisational matter addressed in the platform's terms and insurance arrangements rather than a software control. (POLICY)

Appendix — How these controls were verified

The controls above are covered by an automated regression test suite that runs against the live backend. Latest run:

19 passed in 5.44s

Key automated checks include:

- Financial data (price) is never sent to the AI comparison tool
- Buyer classification: the classifier is blocked (403) from verifying their own entry
- Fee waiver: the requester is blocked (403) from approving their own waiver
- Integrity: a resolved/overridden case cannot be silently re-resolved
- Senior override is written to the exceptions register
- Public incident/SLA endpoint exposes only safe fields (no internal data)

All demonstration records shown in the screenshots were clearly marked (DEMO) and removed after capture; the audit ledger is append-only by design.